

Otoño 2026

Actividad 12

LAB. FILE PATH TRAVERSAL

VALIDATION OF FILE EXTENSION
WITH NULL BYTE BYPASS

CNO IV: Seguridad Informática

Fabiola Calvillo Galván 182455

Mtro. Servando López Contreras

LABORATORIO:

FILE PATH TRAVERSAL

VALIDATION OF FILE EXTENSION WITH NULL BYTE BYPASS

Introducción

Nombre del laboratorio: File Path Traversal: Validation of File Extension with Null Byte Bypass

Nivel del Laboratorio: Practitioner

Tipo de explotación: Path Traversal (Directory Traversal) con bypass mediante Null Byte (%00). La vulnerabilidad permite manipular el nombre de un archivo solicitado para acceder a archivos fuera del directorio permitido. En este caso, se utiliza un byte nulo codificado (%00) para evadir la validación de la extensión del archivo.

Objetivo del laboratorio

El objetivo es obtener el contenido del archivo **/etc/passwd** aprovechando una vulnerabilidad de Path Traversal en la funcionalidad que muestra las imágenes de los productos.

La aplicación intenta impedir el acceso a archivos que no tengan la extensión esperada, pero su validación puede ser evadida mediante un Null Byte.

Explicación Técnica de la Explotación

La aplicación recibe mediante un parámetro el nombre de la imagen que debe mostrar. Antes de procesarlo, comprueba que el nombre termine con una extensión determinada, por **ejemplo .jpg**. El problema aparece cuando se introduce un Null Byte (%00) dentro del nombre del archivo.

El payload puede seguir una estructura como: **../../../../etc/passwd%00.jpg**

La validación puede interpretar que el nombre termina en .jpg, por lo que considera que el archivo es válido. Posteriormente, dependiendo de cómo el servidor procese la cadena, el %00 puede actuar como terminador de la cadena y hacer que la extensión agregada después sea ignorada. De esta manera, la aplicación puede terminar intentando acceder realmente a: **/etc/passwd** en lugar de una imagen.

Explotación

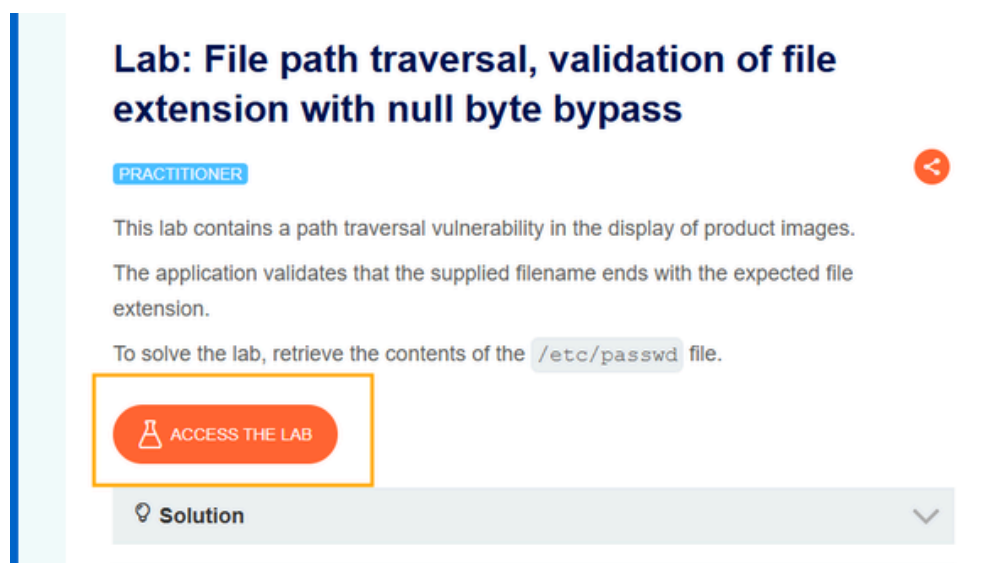
Primero se identifica la petición utilizada para cargar una imagen de producto. Por ejemplo, podría tener una estructura similar a: **/image?filename=...**

Se modifica el parámetro filename utilizando traversal y el Null Byte: **../../../../etc/passwd%00.jpg**

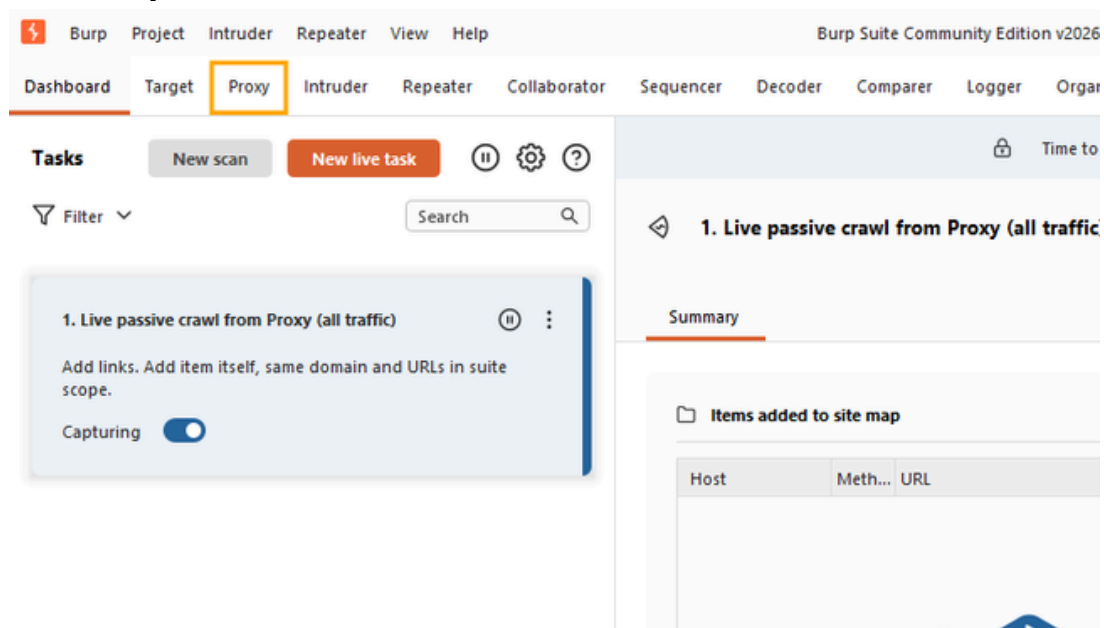
La cantidad de ../ necesaria depende de la ubicación del directorio desde el cual la aplicación intenta cargar las imágenes. El objetivo final es conseguir que la respuesta HTTP muestre el contenido de: **/etc/passwd**

Procedimiento paso a paso

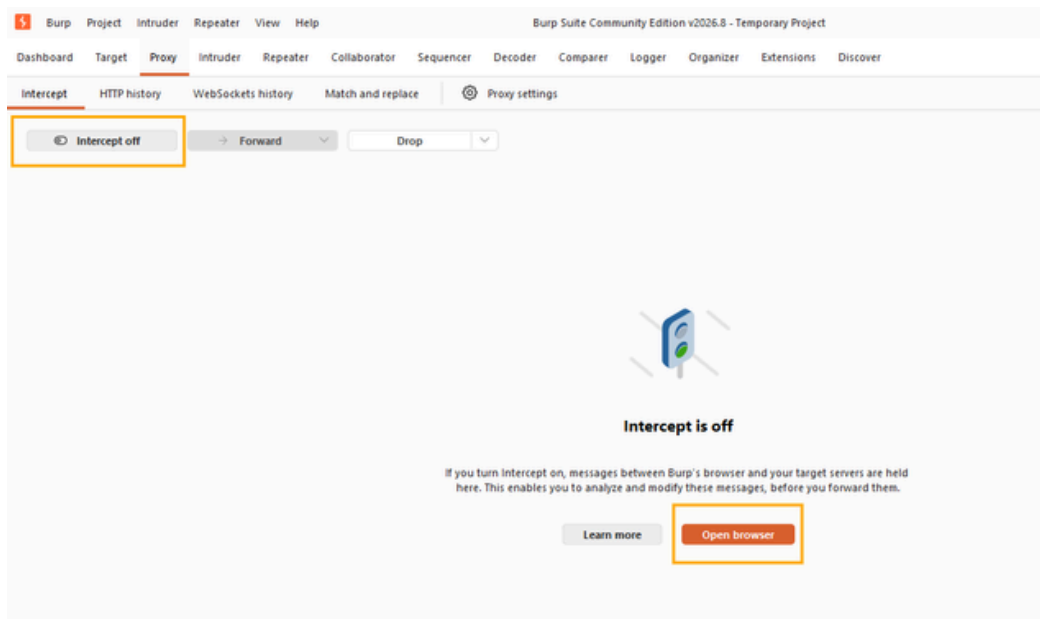
Primero deberemos acceder a la página en donde podremos ingresar a nuestra práctica de laboratorio.



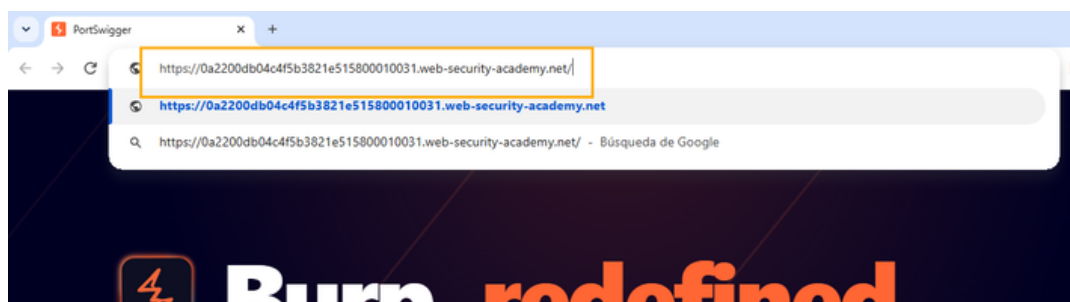
Después de haber ingresado, debemos iniciar BurpSuite, que es en donde estaremos realizando la práctica. Continuando, una vez iniciado BurpSuite, debemos de movernos a la pestaña de **Proxy**.



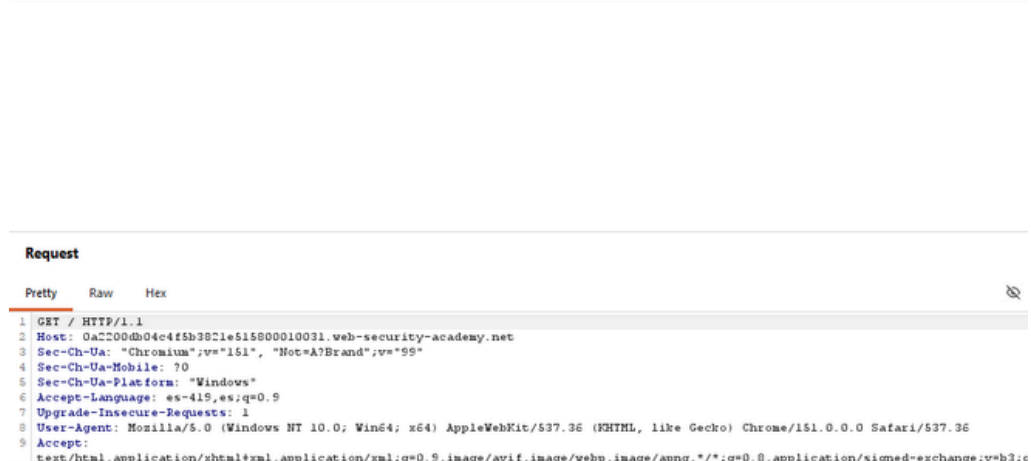
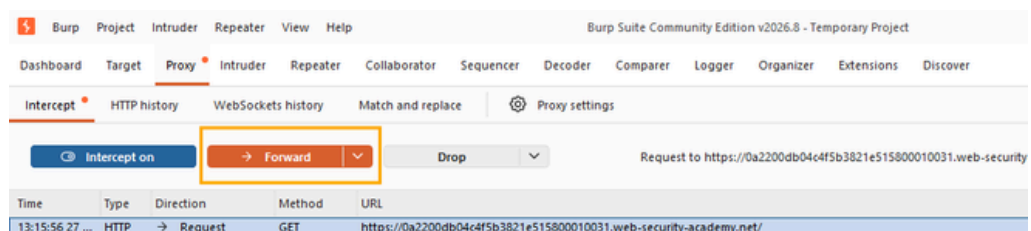
Una vez en la pestaña de **Proxy**, podemos ver que el **Intercept** está apagado, por lo que debemos encenderlo, para así dar clic en **Open Browser**.



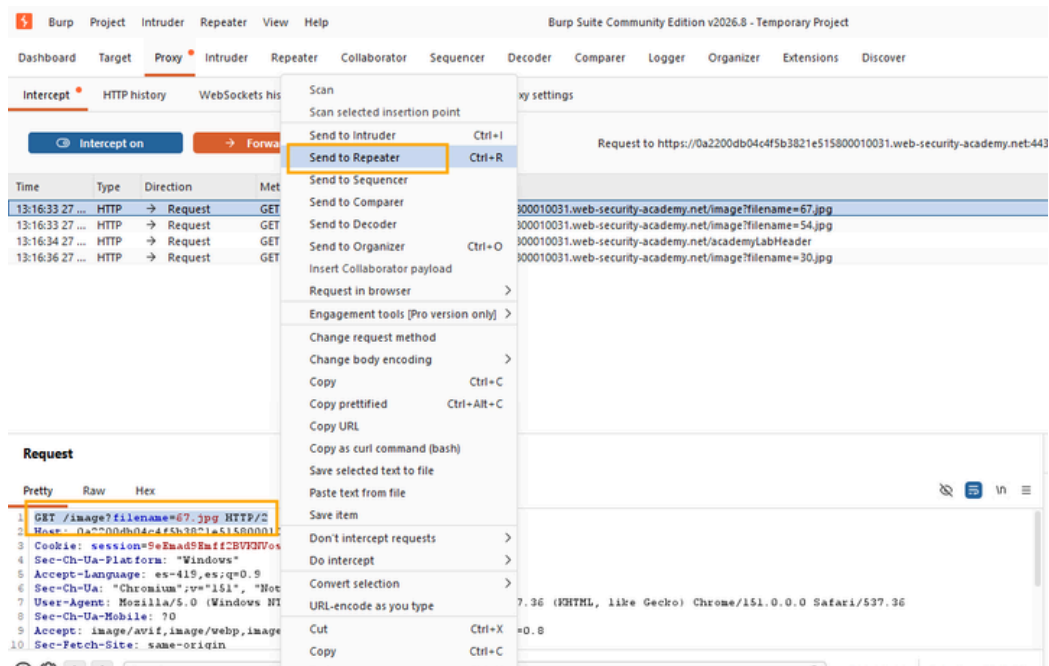
Una vez abierto el navegador deberemos ingresar el enlace de la práctica.



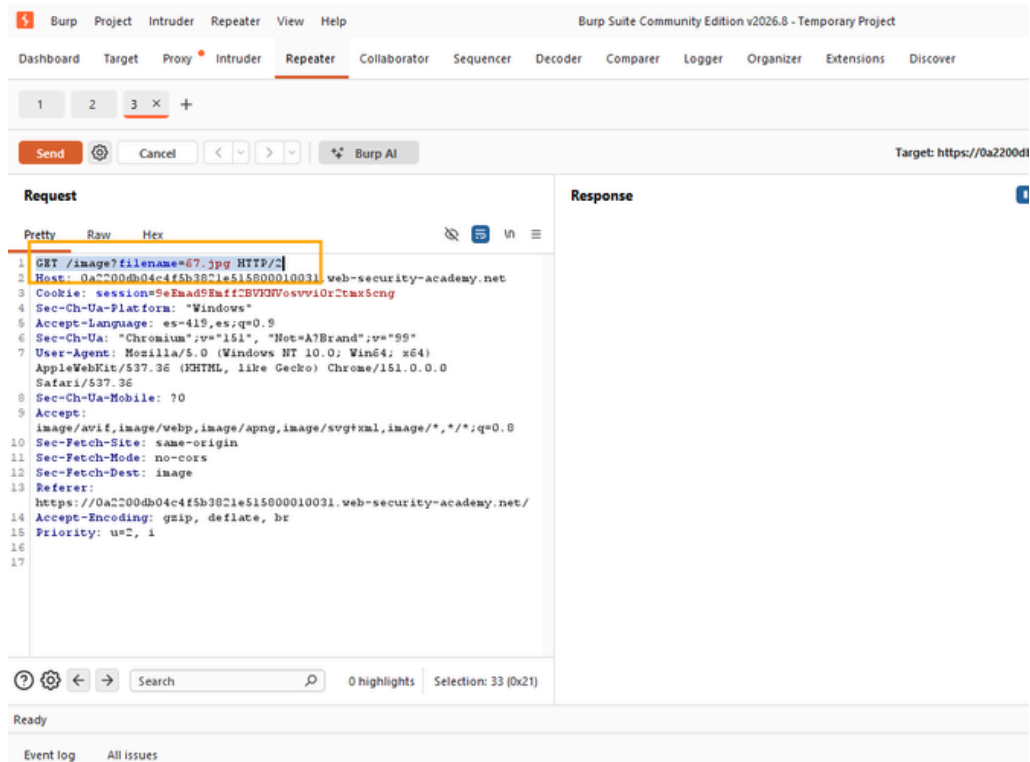
Ya que ingresamos el enlace, nos moveremos a la ventana de BurpSuite, en donde veremos todas las acciones que se llegan hacer para que la página cargue. Para poder realizar la práctica debemos de dar clic en **Forward** hasta que en las peticiones nos aparezca la ruta de una imagen.



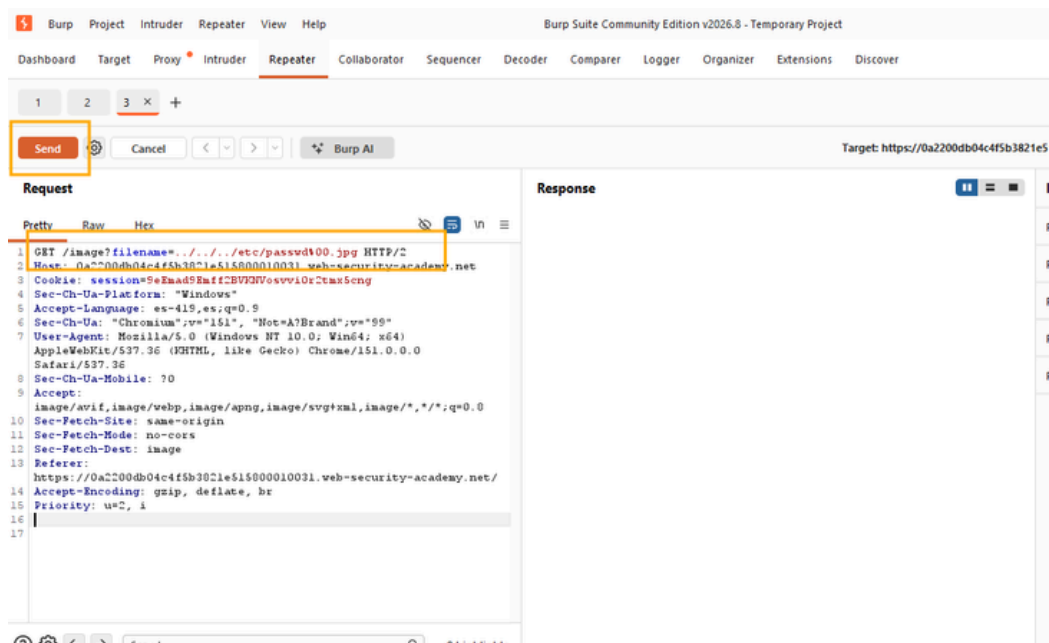
Ya que ubicamos el endpoint, debemos seleccionarlo y dar clic derecho sobre lo seleccionado, para que se nos despliegue un menú en el cual se mostrarán diferentes opciones, nosotros en este caso seleccionaremos la opción de **Send to Repeater** (Enviar al Repetidor).



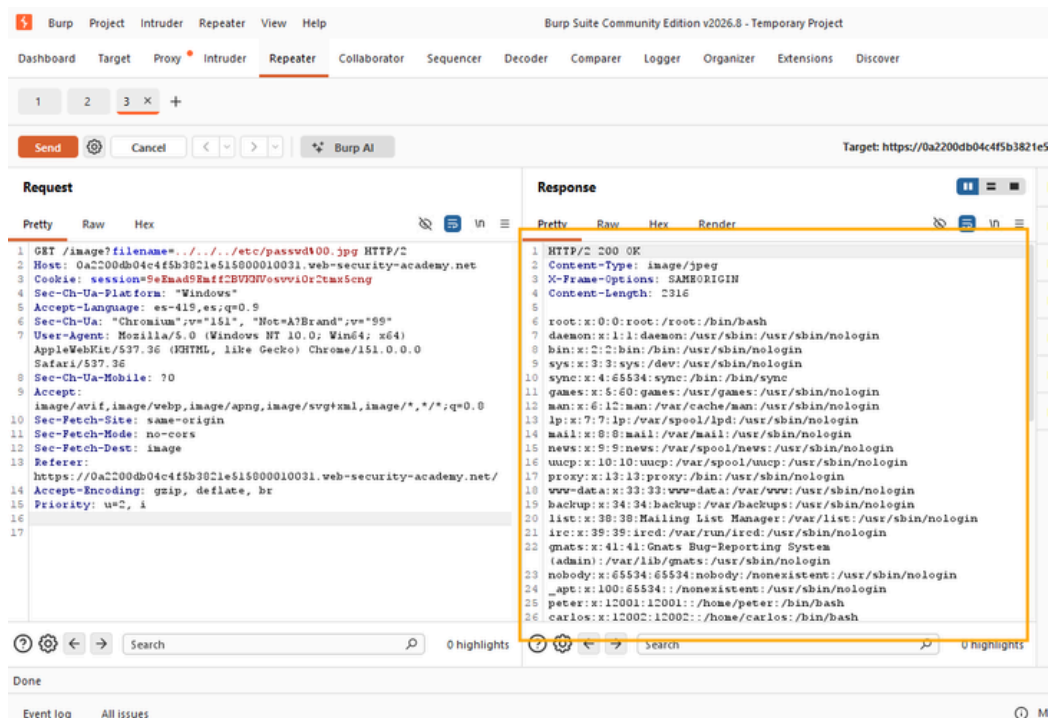
Después de haber mandado esta intrucción al repetidor, debemos movernos a la pestaña de **Repeater**, en donde cambiaremos la ruta para que se pueda abrir la imagen. Aquí podemos observar la ruta antes de ser modificada.



Ahora procederemos a modificar el payload, lo cambiaremos por lo siguiente: GET /image? filename= ../../../../etc/passwd%00.jpg y damos clic en **Send**.

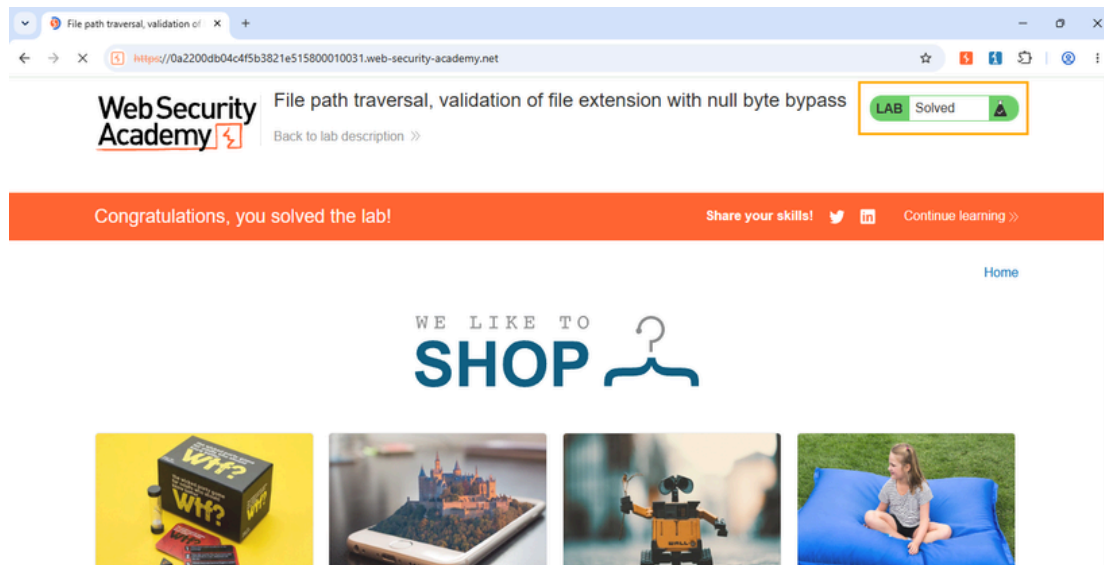


Una vez que dimos clic en **Send**, se deberá mostrar el contenido del directorio en el apartado de **Response**.



Al poder observar esta información, esto nos indica que nuestra práctica está terminada de manera satisfactoria.

Para confirmar que nuestra práctica ya está completa debemos irnos a la página de la práctica, en donde se deberá ver que ya está completada.



Explicación del Payload

El payload utilizado es:

../../../../etc/passwd%00.jpg

Se puede dividir de esta manera:

Desglose	Función
../	Retrocede un directorio en la estructura de archivos.
../../../../	Intenta salir del directorio donde se encuentran las imágenes.
etc/passwd	Especifica el archivo que se intenta obtener.
%00	Representa un Null Byte codificado.
.jpg	Busca satisfacer la validación que exige una extensión de imagen.

La parte más importante es: **%00.jpg**

La aplicación puede comprobar la cadena completa y detectar .jpg, pero una función posterior de procesamiento de archivos puede interpretar el Null Byte como el final de la cadena. Esto permite que la validación y el procesamiento del archivo tengan comportamientos diferentes.

Mitigación Recomendada

La principal medida es no confiar en la entrada proporcionada por el usuario y evitar que el usuario controle directamente las rutas de archivos.

Se recomienda:

- Resolver la ruta mediante funciones seguras y comprobar que la ruta resultante permanezca dentro del directorio autorizado.
- No confiar únicamente en comprobar extensiones como .jpg, .png, etc.
- Rechazar caracteres y secuencias utilizadas para traversal, como ../, aunque esto por sí solo no debe considerarse una defensa suficiente.
- Manejar correctamente los Null Bytes y realizar la validación sobre la cadena que realmente será utilizada para acceder al archivo.
- Aplicar permisos mínimos al usuario con el que se ejecuta la aplicación para limitar el impacto de una posible vulnerabilidad.